Emergency Training Simulator POC

Markdown documentation PDF copy

Demo-day security checklist

Source: docs/security/demo-day-checklist.md

Markdown stays editable. This PDF is the reading/share copy.

Boundary: this project is still a POC, not operational guidance.

Demo-day security checklist

Use this before showing the POC to someone else.

This checklist is not production security. It is a quick way to keep the local demo clean, predictable, and honest.

Before the demo

- Pull the latest main.
- Create or activate the virtual environment.
- Install dev dependencies if needed.
- Run the tests.
- Run the one-command demo once by yourself.
- Clear old demo logs if they might confuse the walkthrough.
- Make sure no real trainee, patient, emergency, or personal data is in the demo.

Useful commands:

```
python -m pytest -q
python -m ruff check backend scripts
python -m compileall -q backend scripts docs\presentations\build_pdf.py
python scripts\run_local_demo.py
```

During the demo

- Say clearly that this is a local POC.
- Say clearly that validation means POC rule checking, not real emergency guidance.
- Show that the backend owns the scenario state.
- Show that the client only sends requested actions.
- Show replay and review as the proof point.
- Avoid changing scenario files live unless that is the demo topic.

Input safety

The backend currently rejects:

- unexpected message fields
- weird or path-like IDs
- unsafe scenario IDs
- unsafe action names
- oversized or deeply nested payloads
- wrong sequence numbers
- duplicate event IDs
- too many active sessions
- too many actions in one session

Log safety

- Logs are local JSONL files under logs/sessions/.
- Logs should generally not be committed.
- Use fake IDs only.
- Do not use real incident, medical, trainee, or patient data.

If something breaks

Keep it simple:

1. Stop the backend.
2. Rerun tests.
3. Rerun python scripts\run_local_demo.py.
4. If a log looks confusing, start a fresh demo with a new session ID.

Do not explain a broken local demo as if it proves real training behavior. It only proves the POC code path.